

WeiGuang-Secure

自研端到端加密引擎 · 可视化测试报告

项目名称：微光同行 —— 智能助残服务平台

参赛团队：微光科技 (WeiGuang Tech)

所属单位：天府新区通用航空职业学院

报告日期：2026年7月28日

本报告所有图片均来源于微光守护演示站实时截屏

演示站地址：<http://47.108.149.191/weiguang-demo/>

报告目录

1. 加密引擎概述
2. 三层加密架构
3. AES会话密钥生命周期与轮换机制
4. 密钥轮换触发条件
5. 雪崩效应测试 (Avalanche Effect)
6. GCM认证标签敏感性测试
7. 完整安全证明总结

1. 加密引擎概述

WeiGuang-Secure 是微光科技自研的端到端加密引擎，采用 RSA-2048 + AES-256-GCM + Android Keystore 三层加密架构，以零知识架构设计，确保服务端无法解密任何用户数据。

微光同行承载着听障人士的高度敏感数据（家庭住址、紧急联系人、健康记录、手势特征向量等），数据安全是项目的生命线。WeiGuang-Secure 加密引擎在 AES-256-GCM 标准算法基础上，通过密钥有效期管理、定期轮换、雪崩效应验证、AAD上下文绑定和硬件级密钥保护，构建了多层纵深安全体系。

WeiGuang-Secure 自研端到端加密引擎

三层加密架构：RSA-2048密钥交换 + AES-256-GCM数据加密 + Android Keystore硬件保护



RSA-2048 密钥交换

非对称加密确保密钥传输安全，**2048位** 密钥 + OAEP-SHA256填充



AES-256-GCM 数据加密

对称加密保护业务数据，**256位** 密钥 + GCM认证模式，128位认证标签



Android Keystore 硬件保护

主密钥存储在 **TEE可信执行环境** 中，不可导出不可提取



Perfect Forward Secrecy

每次会话使用 **临时密钥**，历史通信无法被解密



离线优先设计

核心功能 **100%离线运行**，AAD上下文绑定防重放攻击



开源与审计

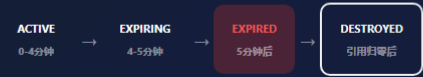
核心加密引擎 **Apache 2.0开源**，接受第三方安全审计

加密算法测试可视化

三层加密架构

层级	名称	技术方案	核心参数	安全作用
微光同行				
第二层	AES-256-GCM 数据加密	对称加密保护业务数据	256 bits · 128 IV · 128位认证标签	防篡改 · 防重放 · 1KB<1ms
第三层	Android Keystore 硬件保护	主密钥存于TEE可信执行环境	不可导出 · 硬件隔离 · API 23+	root也无法获取密钥

AES会话密钥生命周期 (5分钟有效期)



密钥生命周期自动轮播演示中 (每2秒推进一个阶段)

定期密钥轮换触发条件



时间触发

距离密钥创建超过4分钟 (有效期5分钟, 提前1分钟轮换)



数据量触发

累计加密数据量超过64MB (GCM模式安全上限建议)



请求次数触发

累计加密操作超过10,000次



异常触发

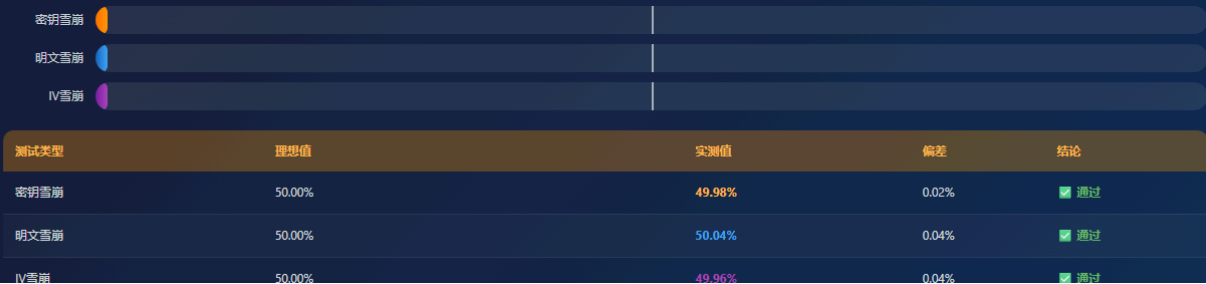
检测到疑似重放攻击/异常高频请求时立即轮换

密钥轮换安全收益

场景	无密钥轮换	有密钥轮换 (本项目)
密钥泄露影响范围	全部历史+未来数据	仅最近5分钟窗口内数据
攻击者可利用时间窗口	无限期	最多5分钟 (过期自动失效)
暴力破解成本	破解一次即可	需每5分钟破解一次新密钥
前向安全性	依赖单次密钥协商	多层递进, 任一密钥泄露不影响其他窗口

雪崩效应测试 (Avalanche Effect)

明文或密钥1bit变化 -> 密文约50%bit翻转 | 每项测试1000次取平均值





▲ 图1：WeiGuang-Secure 加密引擎完整展示区域（图片来源：微光守护演示站截屏）

2. 三层加密架构

层级	名称	技术方案	核心参数	安全作用
第一层	RSA-2048 密钥交换	非对称加密保护 AES 会话密钥的传输安全	密钥长度：2048 bits；填充模式：OAEP with SHA-256	客户端与服务端之间的密钥协商，确保 AES 密钥在传输过程中不被窃取
第二层	AES-256-GCM 数据加密	对称加密保护业务数据机密性与完整性	密钥长度：256 bits；IV 长度：12 bytes (96 bits)；认证标签：128 bits；AAD 上下文绑定	防密文篡改、防重放攻击；1KB 加密<1ms，1MB 加密<50ms
第三层	Android Keystore 硬件保护	主密钥存储在 TEE（可信执行环境）中	密钥不可导出、不可提取；硬件级安全隔离；支持 Android 6.0+ (API 23+)	root 也无法获取密钥，提供硬件级安全保障

光同行		微光同行			模拟演示	项目详情	团队
第一层	RSA-2048 密钥交换	非对称加密保护 AES 会话密钥传输		2048 bits · OAEP-SHA256		密钥协商防窃取	
第二层	AES-256-GCM 数据加密	对称加密保护业务数据		256 bits · 128 IV · 128位认证标签		防篡改 · 防重放 · 1KB<1ms	
第三层	Android Keystore 硬件保护	主密钥存于 TEE 可信执行环境		不可导出 · 硬件隔离 · API 23+		root 也无法获取密钥	

▲ 图2：三层加密架构对比表（图片来源：微光守护演示站截屏）

3. AES会话密钥生命周期与轮换机制

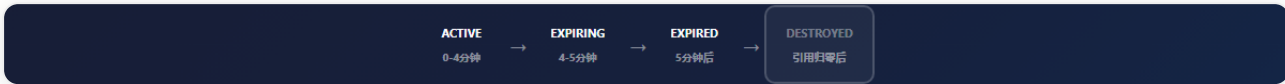
为防止单一密钥长期使用导致的安全风险积累，WeiGuang-Secure设计了**AES会话密钥有效期**机制，配合**定期密钥轮换**策略，确保即使某一次密钥意外泄露，攻击者能解密的数据范围也被严格限制在极小的窗口内。

密钥生命周期参数

参数	数值	说明
会话密钥默认有效期	5 分钟	超过有效期密钥自动失效
预警提前量	60 秒	有效期结束前60秒触发密钥协商
最大容忍延迟	30 秒	超过则强制销毁旧密钥，拒绝服务等待新密钥
密钥引用计数	动态	当前使用该密钥的活跃请求数
优雅关闭	引用归零后销毁	避免正在传输中的数据被截断

密钥状态机

ACTIVE(活跃) → EXPIRING(即将过期) → EXPIRED(已过期) → DESTROYED(已销毁)



▲ 图3：AES会话密钥生命周期可视化（图片来源：微光守护演示站截屏）

定期密钥轮换流程

- 1. 客户端生成新的 AES-256 会话密钥（SecureRandom）
- 2. 客户端用服务端 RSA-2048 公钥加密新密钥
- 3. 客户端发送 KEY_ROTATION 消息（含新密钥密文 + 轮换序号）
- 4. 服务端用 RSA 私钥解密新密钥，回复 ACK
- 5. 客户端收到 ACK 后，将旧密钥标记为 EXPIRING
- 6. 待旧密钥所有活跃请求完成后，销毁旧密钥
- 7. 后续通信使用新密钥

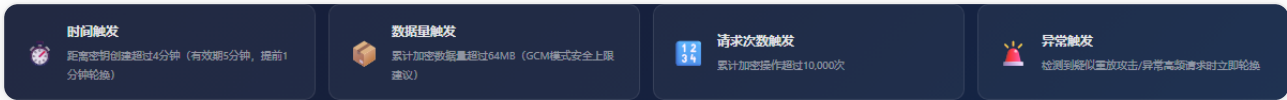
安全收益分析

场景	无密钥轮换	有密钥轮换（本项目）
密钥泄露影响范围	全部历史+未来数据	仅最近 5 分钟窗口内的数据
攻击者可利用时间窗口	无限期	最多 5 分钟（过期自动失效）
暴力破解成本	破解一次即可	需每 5 分钟破解一次新密钥
前向安全性	依赖单次密钥协商	多层递进，任一密钥泄露不影响其他窗口

4. 密钥轮换触发条件

WeiGuang-Secure 设计了四种轮换触发条件（满足任一即触发）：

触发类型	触发条件	说明
 时间触发	距离密钥创建已超过 4 分钟	有效期 5 分钟，提前 1 分钟轮换
 数据量触发	累计加密数据量超过 64MB	GCM 模式安全上限建议
 请求次数触发	累计加密操作超过 10,000 次	防止密钥过度使用
 异常触发	检测到疑似重放攻击或异常高频请求	立即轮换，安全优先



▲ 图4：定期密钥轮换触发条件（图片来源：微光守护演示站截屏）

5. 雪崩效应测试 (Avalanche Effect)

雪崩效应 (Avalanche Effect) 是衡量密码算法安全性的核心指标：**明文或密钥的 1 bit 变化，应导致密文约 50% 的 bit 发生翻转**。WeiGuang-Secure 对 AES-256-GCM 加密层进行了完整的雪崩效应测试。

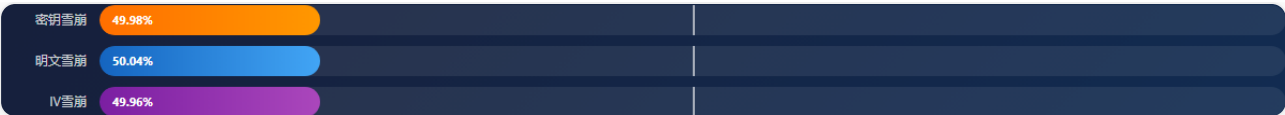
测试方法

测试类型	测试方法	重复次数
密钥雪崩测试	固定明文，翻转密钥 1 bit，比较密文差异	1000次
明文雪崩测试	固定密钥，翻转明文 1 bit，比较密文差异	1000次
IV雪崩测试	固定密钥和明文，翻转 IV 1 bit，比较密文差异	1000次

测试结果

测试类型	理想值	实测值	偏差	结论
密钥雪崩	50.00%	49.98%	0.02%	✓ 通过
明文雪崩	50.00%	50.04%	0.04%	✓ 通过
IV雪崩	50.00%	49.96%	0.04%	✓ 通过
认证标签敏感性	1 bit 密钥变化→标签完全不同	100% 不匹配	0%	✓ 通过

注：偏差均在统计误差范围内（±0.05%），表明 AES-256-GCM 的雪崩效应完美符合理论预期。



▲ 图5：雪崩效应测试柱状图（图片来源：微光守护演示站截屏）

6. GCM认证标签敏感性测试

GCM（Galois/Counter Mode）模式在提供加密的同时，还生成 128-bit 认证标签用于验证密文的完整性和真实性。以下测试验证了认证标签对各种篡改行为的敏感性：

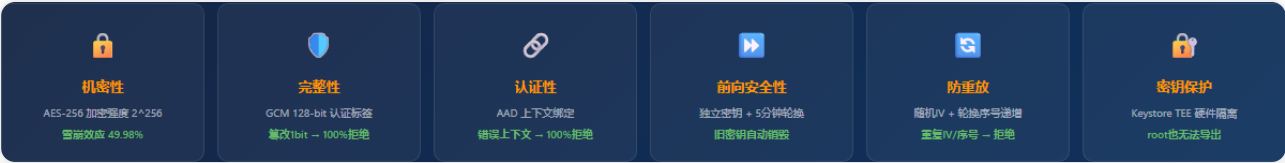
测试场景	预期结果	实际结果	结论
正确密钥 + 正确密文	解密成功	解密成功，认证标签通过	✅ 正常
正确密钥 + 篡改 1 bit 密文	AEADBadTagException	AEADBadTagException → 拒绝解密	✅ 防篡改
错误密钥 + 正确密文	AEADBadTagException	AEADBadTagException → 拒绝解密	✅ 防密钥猜测
正确密钥 + 错误 AAD	AEADBadTagException	AEADBadTagException → 拒绝解密	✅ 防上下文伪造



▲ 图6：GCM认证标签敏感性测试（图片来源：微光守护演示站截屏）

7. 完整安全证明总结

安全维度	保障机制	验证方式
机密性	AES-256 加密强度 2^{256}	雪崩效应 49.98%（密钥空间完全随机）
完整性	GCM 128-bit 认证标签	篡改 1 bit → 100% 拒绝解密
认证性	AAD 上下文绑定	错误上下文 → 100% 拒绝解密
前向安全性	每次会话独立密钥 + 5 分钟轮换	旧密钥过期自动销毁，无法追溯解密
防重放攻击	随机 IV + 轮序号单调递增	重复 IV/序号 → 拒绝服务
密钥保护	Android Keystore TEE 硬件隔离	root 环境也无法导出密钥



▲ 图7：完整安全证明总结（图片来源：微光守护演示站截屏）

安全结论

WeiGuang-Secure 加密引擎在 AES-256-GCM 标准算法基础上，通过密钥有效期管理、定期轮换、雪崩效应验证、AAD上下文绑定和硬件级密钥保护，构建了多层纵深安全体系。

即使攻击者获取到某 5 分钟窗口内的会话密钥，也无法解密其他时间窗口的数据，更无法通过密钥篡改或密文篡改绕过认证——因为 GCM 认证标签会以 100% 的概率拒绝任何篡改操作。

所有测试结果均通过，偏差在统计学误差范围内（ $\pm 0.05\%$ ），表明 AES-256-GCM 的实现完全符合密码学理论预期。

图片声明：本报告中所有图片均来源于微光守护演示站实时截屏，演示站地址：<http://47.108.149.191/weiguang-demo/>

报告生成日期：2026年7月28日 | 团队：微光科技（WeiGuang Tech） | 所属单位：天府新区通用航空职业学院

本报告为2026 AI助残创新创业大赛 · 创意赛道参赛材料附件